PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Authentification et gestion des mots de passe

03-1020 ANSSI - Recommandations relatives à l'authentification multifacteur et aux mots de passe — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'authentification multifacteur doit combiner au moins deux facteurs appartenant à des catégories différentes comme la connaissance, la possession ou l'inhérence.
2. La robustesse d'un mot de passe dépend de son entropie, laquelle est renforcée par une longueur accrue plutôt que par la seule complexité.
3. Le stockage sécurisé des mots de passe nécessite l'utilisation d'un sel aléatoire et de fonctions de hachage spécifiques comme scrypt, Argon2 ou PBKDF2.

Principes de l'authentification

Notion	À retenir
Catégories facteurs	Distinction entre **connaissance**, **possession**, **inhérence** et parfois la **localisation** (où je suis).
Menaces	Mots de passe : **recherche exhaustive**, **dictionnaire**, **password spraying**, **hameçonnage**, **écoute**. Possession : **vol de secrets**. Inhérence : **leurre biométrique** (photo/vidéo).
Multifacteur/Forte	**R1** : privilégier le multifacteur. **R2** : privilégier l'authentification forte (au moins **un facteur fort**). **R3** : conduire une **analyse de risque** selon le contexte.
Cycle de vie des facteurs	Création en environnement maîtrisé (**aléa robuste**), remise par canal sécurisé ; renouvellement, révocation. **R8 : pas de SMS** pour recevoir un facteur. Limiter tentatives et durée de session ; ne pas révéler la **cause d'un échec**.

Synthèse des recommandations mots de passe

Notion	À retenir
Politique et longueur	Allonger augmente l'**entropie**. Sensibilité faible/moyenne : **9 à 11** car. (**65 bits**). Moyenne/forte : **12 à 14** car. (**85 bits**). Forte/très forte : **≥ 15** car. (**≥ 100 bits**).
Longueur maximale	Ne pas fixer de limite faible (**8** ou **10** car.) pour permettre les **phrases de passe**. Limite de **plusieurs centaines** de caractères pour éviter le **déni de service**.
Complexité et expiration	Complexité peut être allégée si mot de passe **très long**. Expiration : pas par défaut pour comptes non sensibles ; **1 à 3 ans** pour comptes à privilèges. Révocation **immédiate** si compromission.
Stockage	Utiliser un **sel aléatoire long** et fonction **memory-hard** (`scrypt` ou `Argon2`) ou fonction itérative (`PBKDF2`) avec **maximum d'itérations**. Prévoir **recouvrement** et **coffre-fort**.
Recommandations utilisateurs	Utiliser des mots de passe **robustes** et **différents** par service. Utiliser un **coffre-fort**, protéger ses mots de passe, soigner celui de la **messagerie**, éviter les **informations personnelles** et modifier les **mots de passe par défaut**.

Seuils d'entropie et de longueur

> 20
caractères
mots de passe non mémorisés, sensibilité forte à très forte

1 à 3
ans
expiration des comptes à privilèges

3
échecs
seuil de blocage pour les codes PIN

Facteurs de possession et d'inhérence

Notion	À retenir
Le facteur de possession	Privilégier un composant **qualifié ou certifié**, à défaut un **composant de sécurité**, ou un facteur **sans composant de sécurité**.
Le facteur inhérent	Jamais **seul** : l'associer à un **facteur fort**. Enregistrement biométrique de préférence **en présence**.

Pièges et confusions

- ⚠ Confondre la double authentification (deux facteurs de même catégorie) avec l'authentification multifacteur.
- ⚠ Utiliser le SMS pour recevoir un facteur d'authentification.
- ⚠ Fixer une longueur maximale faible pour les mots de passe.
- ⚠ Appliquer l'expiration périodique par défaut aux comptes non sensibles.
- ⚠ Utiliser la biométrie comme seul facteur d'authentification.

Sigles et définitions

Facteur de connaissance — Information mémorisée comme un mot de passe, une phrase de passe ou un code.

Facteur de possession — Secret non mémorisable contenu dans un objet physique comme une carte à puce ou un téléphone.

Facteur inhérent — Caractéristique biologique, morphologique ou comportementale indissociable de la personne.

Authentification forte — Mécanisme reposant sur un dispositif cryptographique robuste comme FIDO2 ou les certificats sur carte à puce.

Entropie — Mesure de la robustesse d'un mot de passe exprimée en bits selon le nombre de combinaisons possibles.

Sel — Valeur aléatoire ajoutée au mot de passe avant le calcul de son empreinte.

Password spraying — Test automatique d'un petit nombre de mots de passe courants sur de nombreux comptes.

Auto-test

1. Quelle est la différence entre la double authentification et l'authentification multifacteur ?
2. Quelle est la durée d'expiration recommandée pour les comptes à privilèges ?
3. Combien de caractères minimum faut-il pour une sensibilité forte à très forte ?
4. Quel est le seuil de blocage pour les codes PIN ?
5. Quel type de logiciel permet de stocker de manière chiffrée les mots de passe ?

Réponses : **1.** La double authentification combine deux facteurs de la même catégorie. · **2.** 1 à 3 ans. · **3.** ≥ 15 caractères. · **4.** 3 échecs. · **5.** Un coffre-fort de mots de passe.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.